

NovaPay Executive Summary

ISO/IEC 27001-aligned GRC assessment for management

Prepared by	Bola
Organisation	NovaPay Solutions Ltd. (fictional case study)
Industry	FinTech / Digital Payments
Framework	ISO/IEC 27001:2022
Purpose	Cybersecurity GRC portfolio project

Portfolio disclaimer: NovaPay Solutions Ltd. is a fictional organisation adapted from the supplied PayNest capstone case study. No real employer, customer or production data is used.

Executive Summary

NovaPay Solutions Ltd. is a growing Ireland-based fintech company providing digital payment services to individuals and small businesses across Ireland and selected European markets. The business handles customer information, transaction data, employee information, financial records, application/source code and cloud-based systems. As the organisation scales, management wants a more formal, repeatable and evidence-driven approach to information security.

incomplete, inconsistent or not supported by sufficient evidence. The main challenge is therefore not simply adding more technical controls. NovaPay needs a repeatable management system that links scope, assets, risk decisions, controls, ownership, evidence and continual improvement.

Key Findings

- The ISMS boundary has not been formally defined.
- Security policies are incomplete and a formal asset inventory is absent.
- Risk assessments and control-selection decisions are inconsistent.
- A Statement of Applicability has not been established.
- Security awareness training and third-party security checks are inconsistent.
- Evidence of formal objectives, internal audit, management review and several technical control processes was not provided.

Risk Position

The risk register identifies 12 priority scenarios. The highest inherent scores relate to unauthorized access to customer/transaction data and a number of critical business dependencies including phishing, supplier compromise, secure development, payment-service availability and compliance exposure. Where current control effectiveness was not evidenced, the assessment deliberately avoided reducing the residual score.

Management Priorities

- Approve the ISMS scope, governance roles and risk criteria.
- Establish a formal asset inventory and information-classification approach.
- Approve the risk register, treatment plan and selected-control SoA.
- Prioritize access governance, supplier security, secure development, vulnerability management, monitoring, incident response and continuity.
- Implement measurable security objectives and evidence collection.
- Complete internal audit, corrective action and management review before deciding on external certification readiness.

Conclusion

NovaPay should move from reactive security decisions to a defined, risk-based and evidence-driven ISMS. The six-month roadmap provides a practical path to establish that foundation, but readiness should be based on demonstrated control effectiveness rather than completion of documents alone.